

CRISC Exam - Hard Questions with Explanations

From Open Source CRISC Exam Guide

Compiled from GTPs and AI

July 18, 2026

Outline

- 1 Domain 1: Governance
- 2 Domain 1: 3 Lines of Defense
- 3 Domain 1: Legal and Ethics
- 4 Domain 2: Risk Management Life Cycle
- 5 Domain 2: Threat, Vulnerability, Risk
- 6 Domain 2: Risk Assessment Frameworks
- 7 Domain 2: Business Impact Analysis
- 8 Domain 3: Risk Response
- 9 Domain 3: Third-Party Risk Management
- 10 Domain 3: Control Design
- 11 Domain 3: Monitoring and Reporting
- 12 Domain 4: Enterprise Architecture
- 13 Domain 4: Data Life Cycle
- 14 Domain 4: SDLC
- 15 Domain 4: Information Security

Q1: Organizational Governance

Question

The purpose of having a governance structure is to:

- ☐ A Manage day-to-day operations
- ☐ B Have accountability for business alignment and operations
- ☐ C Implement security controls
- ☐ D Conduct risk assessments

Q1: Explanation

Correct Answer: B

The purpose of having a governance structure is to have accountability for the business alignment and day-to-day operations of the organization.

Option Analysis

- **A - Incorrect:** Management handles day-to-day operations, not governance
- **B - Correct:** Governance establishes accountability for business alignment
- **C - Incorrect:** Controls are implemented at management level
- **D - Incorrect:** Risk assessments are operational activities

Q2: Risk Management First Step

Question

Which of the following is the first step in IT risk management?

- Ⓐ IT risk assessment
- Ⓑ Risk response and mitigation
- Ⓒ IT risk identification
- Ⓓ Risk reporting

Q2: Explanation

Correct Answer: C

IT risk identification is the first step of IT risk management. You cannot protect what you do not know exists.

Option Analysis

- **A - Incorrect:** Assessment comes after identification
- **B - Incorrect:** Response comes after assessment
- **C - Correct:** Identification is the first step
- **D - Incorrect:** Reporting is the final step

Q3: Oversight Responsibility

Question

Oversight and direction are the responsibility of who?

- ☐ A Management
- ☐ B Senior staff
- ☐ C IT risk manager
- ☐ D Board of directors

Q3: Explanation

Correct Answer: D

Oversight and direction are the responsibility of the board of directors.

Option Analysis

- **A - Incorrect:** Management executes, doesn't provide oversight
- **B - Incorrect:** Senior staff don't provide governance oversight
- **C - Incorrect:** Risk manager executes risk activities
- **D - Correct:** Board provides oversight and direction

Q4: Policy Documentation Hierarchy

Question

The high-level intent of an organization's security practices is best established by which of the following?

- ☐ A Procedures
- ☐ B Policies
- ☐ C Guidelines
- ☐ D Processes

Q4: Explanation

Correct Answer: B

Policies are the high-level intent of organizations for security practices.

Option Analysis

- **A - Incorrect:** Procedures are detailed steps
- **B - Correct:** Policies express management intent
- **C - Incorrect:** Guidelines are recommendations
- **D - Incorrect:** Processes are operational

Q5: RACI Model

Question

Which group should be reached out to for expert guidance on the working group?

- ☐ A Responsible
- ☐ B Accountable
- ☐ C Consulted
- ☐ D Informed

Q5: Explanation

Correct Answer: C

Consulted working groups are the subject matter experts for guidance on initiatives in their domain of expertise.

Option Analysis

- **A - Incorrect:** Responsible does the work
- **B - Incorrect:** Accountable provides resources
- **C - Correct:** Consulted are subject matter experts
- **D - Incorrect:** Informed are kept updated

Q6: Risk Culture Focus

Question

An IT risk manager recently joined an organization with past security incidents. What should be the primary focus in the first few months?

- Ⓐ Cite individuals who caused incidents
- Ⓑ Understand the organization's culture toward risk
- Ⓒ Draft strategy for IT risk management
- Ⓓ Complete all security awareness training

Q6: Explanation

Correct Answer: B

The risk manager needs to understand the culture of the organization before drafting strategy.

Option Analysis

- **A - Incorrect:** Blaming individuals is counterproductive
- **B - Correct:** Culture understanding is foundational
- **C - Incorrect:** Strategy comes after understanding culture
- **D - Incorrect:** Training is secondary to culture assessment

Q7: 3LoD Risk Monitoring

Question

In the 3LoD model, which LoD is responsible for risk monitoring and oversight?

- ☐ A First LoD
- ☐ B Second LoD
- ☐ C Third LoD
- ☐ D All of the above

Q7: Explanation

Correct Answer: B

The second LoD is responsible for risk monitoring and oversight.

Option Analysis

- **A - Incorrect:** First LoD is operational management
- **B - Correct:** Second LoD provides oversight and monitoring
- **C - Incorrect:** Third LoD provides independent assurance
- **D - Incorrect:** Only second LoD has this responsibility

Q8: Third LoD Responsibility

Question

What is the primary responsibility of the third LoD?

- Ⓐ Policy and procedure development
- Ⓑ Provide independent assurance of controls
- Ⓒ Perform periodic user reviews
- Ⓓ Restrict least privileged roles

Q8: Explanation

Correct Answer: B

The third LoD is primarily responsible for independent assurance of controls through internal/external audit.

Option Analysis

- **A - Incorrect:** Policy development is second LoD
- **B - Correct:** Independence is key for third LoD
- **C - Incorrect:** User reviews are operational (first LoD)
- **D - Incorrect:** Access control is operational

Q9: Risk Appetite Definition

Question

The amount of risk an organization is willing to accept is known as:

- Ⓐ Risk tolerance
- Ⓑ Risk capacity
- Ⓒ Risk profile
- Ⓓ Risk appetite

Q9: Explanation

Correct Answer: D

Risk appetite is the amount of risk an organization is willing to accept to achieve its objectives.

Option Analysis

- **A - Incorrect:** Tolerance is acceptable variation
- **B - Incorrect:** Capacity is maximum affordable risk
- **C - Incorrect:** Profile is overall exposure
- **D - Correct:** Appetite is willingness to accept

Q10: Risk Acceptance Reason

Question

The BEST reason for a Business Process Owner to accept risk is:

- Ⓐ Difficulty to implement controls
- Ⓑ Unavailability of resources
- Ⓒ Cost of control outweighs cost of assets
- Ⓓ Budgetary constraints

Q10: Explanation

Correct Answer: C

Cost of control implementation should not outweigh the cost of assets.

Option Analysis

- **A - Incorrect:** Difficulty is not a valid reason
- **B - Incorrect:** Resource availability is temporary
- **C - Correct:** Cost-benefit analysis is fundamental
- **D - Incorrect:** Budget constraints are not primary

Q11: Risk Tolerance vs Capacity

Question

Which statement is correct?

- ☐ A Breaching risk tolerance threatens existence
- ☐ B Breaching risk capacity threatens existence
- ☐ C Risk tolerance and capacity are not related
- ☐ D Risk tolerance and capacity are the same

Q11: Explanation

Correct Answer: B

Breaching risk capacity could threaten an organization's existence.

Option Analysis

- **A - Incorrect:** Tolerance breach is manageable
- **B - Correct:** Capacity breach threatens existence
- **C - Incorrect:** They are related
- **D - Incorrect:** They are different concepts

Q12: HIPAA

Question

Which federal law provides guidance on protecting sensitive health information?

- ☐ A CCPA
- ☐ B HIPAA
- ☐ C FFIEC
- ☐ D GDPR

Q12: Explanation

Correct Answer: B

HIPAA is the federal law protecting sensitive health information.

Option Analysis

- **A - Incorrect:** CCPA is California privacy law
- **B - Correct:** HIPAA is health information law
- **C - Incorrect:** FFIEC is banking regulation
- **D - Incorrect:** GDPR is EU regulation

Q13: CCPA Beneficiaries

Question

Which group is a beneficiary of CCPA law?

- ☐ A US residents
- ☐ B EU residents
- ☐ C California residents
- ☐ D Canada residents

Q13: Explanation

Correct Answer: C

CCPA protects California residents' personal information.

Option Analysis

- **A - Incorrect:** US residents is too broad
- **B - Incorrect:** EU residents are covered by GDPR
- **C - Correct:** California residents
- **D - Incorrect:** Canada residents have PIPEDA

Q14: HIPAA Breach Notification

Question

According to HIPAA Breach Notification Rule, when must a CE report a breach to OCR?

- Ⓐ Breach of more than 100 California residents
- Ⓑ IT incident in the CE
- Ⓒ IT incident in business associate
- Ⓓ Breach of health information of more than 500 individuals

Q14: Explanation

Correct Answer: D

Breach of more than 500 individuals must be reported to OCR.

Option Analysis

- **A - Incorrect:** 100 is not the threshold
- **B - Incorrect:** IT incident alone is not a breach
- **C - Incorrect:** Business associate incident may be reported
- **D - Correct:** 500+ individuals requires notification

Q15: ISACA Code of Ethics

Question

Failure to comply with ISACA Code of Ethics could lead to:

- ☐ A Mandatory training from ISACA
- ☐ B Additional questions in exam
- ☐ C Investigation and disciplinary measures
- ☐ D Immediate revocation of certification

Q15: Explanation

Correct Answer: C

ISACA will conduct investigation and take disciplinary actions upon failure to comply with Code of Ethics.

Option Analysis

- **A - Incorrect:** Training is not the only consequence
- **B - Incorrect:** Exam questions are not affected
- **C - Correct:** Investigation and disciplinary measures
- **D - Incorrect:** Revocation may follow investigation

Q16: IT Risk vs Enterprise Risk

Question

Which depicts the correct relationship between IT risk and enterprise risk?

- ☐ A Enterprise risk is part of IT risk
- ☐ B IT risk is part of enterprise risk
- ☐ C These types of risk are not related
- ☐ D Enterprise risk is independent of IT risk

Q16: Explanation

Correct Answer: B

IT risk is a subset of enterprise risk.

Option Analysis

- **A - Incorrect:** Enterprise risk is broader
- **B - Correct:** IT risk is part of enterprise risk
- **C - Incorrect:** They are related
- **D - Incorrect:** IT risk impacts enterprise risk

Q17: Risk Identification Principle

Question

Which risk management life cycle step emphasizes "You can't protect what you don't know exists"?

- ☐ A Risk and control monitoring
- ☐ B Risk assessment
- ☐ C Risk identification
- ☐ D Risk categorization

Q17: Explanation

Correct Answer: C

Risk identification is the first step - you must know risks exist.

Option Analysis

- **A - Incorrect:** Monitoring happens after identification
- **B - Incorrect:** Assessment comes after identification
- **C - Correct:** Identification discovers risks
- **D - Incorrect:** Categorization comes after identification

Q18: Formal Risk Assessment Requirement

Question

Which is a formal requirement by many legal and regulatory compliance frameworks?

- Ⓐ Performing vulnerability assessments
- Ⓑ Maintaining asset inventory
- Ⓒ Deploying changes without testing
- Ⓓ Conducting formal risk assessment

Q18: Explanation

Correct Answer: D

Conducting formal risk assessment is a requirement of many legal and regulatory compliance frameworks.

Option Analysis

- **A - Incorrect:** Vulnerability assessments are important but not universally mandatory
- **B - Incorrect:** Asset inventory is good practice but not always required
- **C - Incorrect:** This is poor practice
- **D - Correct:** Formal risk assessment is widely mandated

Q19: Event vs Incident vs Breach

Question

A healthcare employee accidentally sent more than 5,000 patient records in response to a phishing email. This is a:

- ☐ A Issue
- ☐ B Event
- ☐ C Incident
- ☐ D Breach

Q19: Explanation

Correct Answer: D

This is a breach - unauthorized disclosure of PHI affecting more than 500 individuals.

Option Analysis

- **A - Incorrect:** Issue is a condition, not an occurrence
- **B - Incorrect:** Event alone doesn't cause negative outcome
- **C - Incorrect:** Incident is one or more events with negative outcome
- **D - Correct:** Breach is unauthorized disclosure

Q20: Vulnerability Definition

Question

Which is considered a weakness that could be exploited by a malicious actor?

- ☐ A Threat
- ☐ B Threat actor
- ☐ C Vulnerability
- ☐ D Risk

Q20: Explanation

Correct Answer: C

Vulnerabilities are weaknesses that can be exploited by malicious actors.

Option Analysis

- **A - Incorrect:** Threat is potential cause
- **B - Incorrect:** Threat actor executes the threat
- **C - Correct:** Vulnerability is a weakness
- **D - Incorrect:** Risk is the result of exploitation

Q21: Threat Modeling Phase

Question

"What could go wrong?" corresponds to which phase of threat modeling?

- ☐ A Model
- ☐ B Identify
- ☐ C Mitigate
- ☐ D Validate

Q21: Explanation

Correct Answer: B

Identify phase requires asking "What could go wrong?"

Option Analysis

- **A - Incorrect:** Model is "What are we building?"
- **B - Correct:** Identify is "What could go wrong?"
- **C - Incorrect:** Mitigate is "What countermeasures?"
- **D - Incorrect:** Validate is "Have we performed all steps?"

Question

Which scoring technique is used to quantify a vulnerability?

- ☐ A CSS
- ☐ B CSV
- ☐ C CVSS
- ☐ D CVVS

Q22: Explanation

Correct Answer: C

Common Vulnerability Scoring System (CVSS) is used to quantify vulnerabilities.

Option Analysis

- **A - Incorrect:** CSS is not vulnerability scoring
- **B - Incorrect:** CSV is file format
- **C - Correct:** CVSS is the standard
- **D - Incorrect:** CVVS is not standard

Q23: Quantitative Risk Framework

Question

Which framework is primarily used for quantitative risk management?

- ☐ A NIST 800-30
- ☐ B FAIR
- ☐ C ISO 27001
- ☐ D ISO 27005

Q23: Explanation

Correct Answer: B

FAIR (Factor Analysis of Information Risk) is primarily used for quantitative risk management.

Option Analysis

- **A - Incorrect:** NIST 800-30 is qualitative
- **B - Correct:** FAIR is quantitative
- **C - Incorrect:** ISO 27001 is management standard
- **D - Incorrect:** ISO 27005 is qualitative

Q24: Risk Assessment Approaches

Question

A top-down risk assessment starts from the:

- Ⓐ Team
- Ⓑ Individual
- Ⓒ Organization
- Ⓓ Department

Q24: Explanation

Correct Answer: C

Top-down risk assessment starts from the organization level.

Option Analysis

- **A - Incorrect:** Team is bottom-up
- **B - Incorrect:** Individual is bottom-up
- **C - Correct:** Organization is top-down
- **D - Incorrect:** Department is between top and bottom

Q25: Qualitative Risk True/False

Question

Which is NOT true about qualitative risk management?

- Ⓐ Less expensive
- Ⓑ Subjective
- Ⓒ Requires complex computation
- Ⓓ Focused on severity

Q25: Explanation

Correct Answer: C

Qualitative risk management does NOT require complex computation.

Option Analysis

- **A - True:** Qualitative is less expensive
- **B - True:** Qualitative is subjective
- **C - Not True:** Complex computation is quantitative
- **D - True:** Focused on severity

Q26: Supply Chain Risk Framework

Question

Which NIST framework provides guidance for supply chain management?

- ☐ A NIST 800-161
- ☐ B NIST 800-30
- ☐ C NIST 800-57
- ☐ D ISO 27001

Q26: Explanation

Correct Answer: A

NIST SP 800-161 provides guidance for supply chain risk management.

Option Analysis

- **A - Correct:** 800-161 is supply chain
- **B - Incorrect:** 800-30 is risk management
- **C - Incorrect:** 800-57 is key management
- **D - Incorrect:** ISO 27001 is management standard

Q27: Bow Tie Analysis

Question

Which risk assessment technique provides results by displaying links between possible causes, controls, and consequences in a diagram?

- ☐ A FAIR
- ☐ B BTA
- ☐ C Markov analysis
- ☐ D Monte Carlo analysis

Q27: Explanation

Correct Answer: B

Bow Tie Analysis (BTA) displays links between causes, controls, and consequences in a diagram.

Option Analysis

- **A - Incorrect:** FAIR is quantitative taxonomy
- **B - Correct:** BTA is diagram-based
- **C - Incorrect:** Markov uses state analysis
- **D - Incorrect:** Monte Carlo uses simulation

Q28: Risk Register Output

Question

The results of a risk assessment should be summarized as a(n):

- ☐ A CAP
- ☐ B Business continuity plan
- ☐ C Organizational chart
- ☐ D Risk register

Q28: Explanation

Correct Answer: D

Risk register is the immediate result of a risk assessment.

Option Analysis

- **A - Incorrect:** CAP is corrective action plan
- **B - Incorrect:** BCP is continuity planning
- **C - Incorrect:** Org chart shows structure
- **D - Correct:** Risk register documents risks

Q29: BIA vs Risk Assessment

Question

Which statement is false regarding risk assessment and BIA?

- ☐ A BIA identifies RPO, RTO, MTD
- ☐ B Risk assessment identifies mitigation plans
- ☐ C BCP needs BIA
- ☐ D BIA and risk assessment are the same

Q29: Explanation

Correct Answer: D

BIA and risk assessment are NOT the same.

Option Analysis

- **A - True:** BIA identifies recovery objectives
- **B - True:** Risk assessment identifies mitigation
- **C - True:** BCP needs BIA as input
- **D - Not True:** They are different processes

Q30: RPO Direction

Question

Which is backward-looking in relation to BIA?

- ☐ A RPO
- ☐ B RTO
- ☐ C MTD
- ☐ D SSO

Q30: Explanation

Correct Answer: A

RPO (Recovery Point Objective) is backward-looking - it measures acceptable data loss.

Option Analysis

- **A - Correct:** RPO is backward-looking
- **B - Incorrect:** RTO is forward-looking
- **C - Incorrect:** MTD is total downtime
- **D - Incorrect:** SSO is single sign-on

Q31: Residual Risk

Question

The risk after implementing controls is called:

- ☐ A Current risk
- ☐ B Residual risk
- ☐ C Inherent risk
- ☐ D Total risk

Q31: Explanation

Correct Answer: B

Residual risk = Inherent Risk - Controls. It is the risk remaining after controls are implemented.

Option Analysis

- **A - Incorrect:** Current risk is point-in-time
- **B - Correct:** Residual risk remains after controls
- **C - Incorrect:** Inherent risk is before controls
- **D - Incorrect:** Total risk is before controls

Q32: Current Risk

Question

The risk after implementing controls in a real-time scenario against threats is called:

- Ⓐ Residual risk
- Ⓑ Inherent risk
- Ⓒ Current risk
- Ⓓ Total risk

Q32: Explanation

Correct Answer: C

Current risk is the residual risk in a real-time threat scenario at a specific point in time.

Option Analysis

- **A - Incorrect:** Residual is not real-time
- **B - Incorrect:** Inherent is before controls
- **C - Correct:** Current is real-time residual risk
- **D - Incorrect:** Total risk is before controls

Q33: Risk Owner Purpose

Question

The primary reason for having a risk owner is:

- ☐ A Leverage their resources
- ☐ B Ensure accountability
- ☐ C Provide flexibility
- ☐ D Seek assistance

Q33: Explanation

Correct Answer: B

The risk owner drives accountability in risk remediation.

Option Analysis

- **A - Incorrect:** Resources are secondary
- **B - Correct:** Accountability is primary
- **C - Incorrect:** Flexibility is not primary
- **D - Incorrect:** Assistance is secondary

Q34: NOT a Risk Response Strategy

Question

Which is NOT a risk response strategy?

- Ⓐ Accept
- Ⓑ Transfer
- Ⓒ Treat
- Ⓓ Mitigate

Q34: Explanation

Correct Answer: C

"Treat" is sometimes used interchangeably but is not a formal risk response strategy. The four strategies are Accept, Transfer, Mitigate, and Avoid.

Option Analysis

- **A - Incorrect:** Accept is a strategy
- **B - Incorrect:** Transfer is a strategy
- **C - Correct:** Treat is not a formal strategy
- **D - Incorrect:** Mitigate is a strategy

Q35: Compensating Controls

Question

A risk manager determines primary controls are insufficient and implements compensating controls. This is:

- ☐ A Risk mitigation
- ☐ B Risk acceptance
- ☐ C Risk sharing
- ☐ D Risk avoidance

Q35: Explanation

Correct Answer: A

Implementing additional controls is an example of risk mitigation.

Option Analysis

- **A - Correct:** Adding controls is mitigation
- **B - Incorrect:** Acceptance would do nothing
- **C - Incorrect:** Sharing would involve third party
- **D - Incorrect:** Avoidance would terminate activity

Q36: Insurance as Risk Response

Question

Senior management buys insurance for an earthquake-prone site. This is:

- ☐ A Risk mitigation
- ☐ B Risk acceptance
- ☐ C Risk sharing
- ☐ D Risk avoidance

Q36: Explanation

Correct Answer: C

Insurance transfers/sharing the risk with the insurance company.

Option Analysis

- **A - Incorrect:** Mitigation would reduce risk
- **B - Incorrect:** Acceptance would retain risk
- **C - Correct:** Sharing through insurance
- **D - Incorrect:** Avoidance would close site

Q37: Risk Avoidance

Question

Management terminates onboarding a new tool as it doesn't adapt to changing requirements. This is:

- ☐ A Risk mitigation
- ☐ B Risk acceptance
- ☐ C Risk sharing
- ☐ D Risk avoidance

Q37: Explanation

Correct Answer: D

Terminating a project to eliminate risk is risk avoidance.

Option Analysis

- **A - Incorrect:** Mitigation would modify the tool
- **B - Incorrect:** Acceptance would proceed with risk
- **C - Incorrect:** Sharing would involve third party
- **D - Correct:** Avoidance eliminates the risk

Q38: Remote Work as Risk Response

Question

An organization allows employees to work remotely due to geographical risks. This is:

- Ⓐ Risk mitigation
- Ⓑ Risk acceptance
- Ⓒ Risk sharing
- Ⓓ Risk avoidance

Q38: Explanation

Correct Answer: A

Allowing remote work reduces the impact of geographical risks - this is mitigation.

Option Analysis

- **A - Correct:** Reducing impact through remote work
- **B - Incorrect:** Acceptance would do nothing
- **C - Incorrect:** Sharing would transfer to another
- **D - Incorrect:** Avoidance would close location

Q39: SLA Breach

Question

Which would bind a third party to provide monetary credits in case of service failure?

- Ⓐ Master service agreement
- Ⓑ Service-level agreement
- Ⓒ Non-disclosure agreement
- Ⓓ External audit

Q39: Explanation

Correct Answer: B

A breach in the SLA allows the organization to demand monetary credit.

Option Analysis

- **A - Incorrect:** MSA is general framework
- **B - Correct:** SLA defines service levels and penalties
- **C - Incorrect:** NDA protects confidentiality
- **D - Incorrect:** Audit is verification

Q40: NDA Purpose

Question

Which should be signed with third party to protect intellectual property?

- ☐ A Master service agreement
- ☐ B Service-level agreement
- ☐ C Non-disclosure agreement
- ☐ D External audit

Q40: Explanation

Correct Answer: C

NDA's protect intellectual property and interests of the organization.

Option Analysis

- **A - Incorrect:** MSA is general framework
- **B - Incorrect:** SLA defines service levels
- **C - Correct:** NDA protects IP and confidentiality
- **D - Incorrect:** Audit is verification

Q41: External Audit Output

Question

Which is NOT the final output of an external audit?

- Ⓐ SOC 2 report
- Ⓑ ISO 27001 certification
- Ⓒ HITRUST certification
- Ⓓ Non-disclosure agreement

Q41: Explanation

Correct Answer: D

Non-disclosure agreements are signed internally, not the output of an external audit.

Option Analysis

- **A - Incorrect:** SOC 2 is audit output
- **B - Incorrect:** ISO 27001 is audit output
- **C - Incorrect:** HITRUST is audit output
- **D - Correct:** NDA is not an audit output

Q42: Exception Review Frequency

Question

The risk practitioner should review and verify granted exceptions are still required at least:

- ☐ A Weekly
- ☐ B Monthly
- ☐ C Quarterly
- ☐ D Annually

Q42: Explanation

Correct Answer: D

Granted exceptions should be verified at least annually.

Option Analysis

- **A - Incorrect:** Weekly is too frequent
- **B - Incorrect:** Monthly is too frequent
- **C - Incorrect:** Quarterly is too frequent
- **D - Correct:** Annual review is standard

Q43: CAB Composition

Question

The CAB should consist of which of the following?

- ☐ A Only IT
- ☐ B IT and engineering
- ☐ C IT, engineering, and security
- ☐ D All relevant stakeholders

Q43: Explanation

Correct Answer: D

CAB should consist of all relevant stakeholders.

Option Analysis

- **A - Incorrect:** IT alone is insufficient
- **B - Incorrect:** Engineering alone is insufficient
- **C - Incorrect:** Security is needed but not sufficient
- **D - Correct:** All relevant stakeholders needed

Q44: Control Categories

Question

Which is NOT a control category?

- ☐ A Additive
- ☐ B Preventive
- ☐ C Deterrent
- ☐ D Detective

Q44: Explanation

Correct Answer: A

Additive is not a control category. The categories are Preventive, Detective, Corrective, Deterrent, Compensating.

Option Analysis

- **A - Correct:** Additive is not a control category
- **B - Incorrect:** Preventive is a category
- **C - Incorrect:** Deterrent is a category
- **D - Incorrect:** Detective is a category

Q45: Proactive Control

Question

Implementing controls proactively based on root cause analysis is an example of:

- ☐ A Preventive
- ☐ B Detective
- ☐ C Corrective
- ☐ D Compensating

Q45: Explanation

Correct Answer: A

Implementing controls proactively is an example of preventive control.

Option Analysis

- **A - Correct:** Preventive stops issues before they occur
- **B - Incorrect:** Detective finds issues after
- **C - Incorrect:** Corrective fixes issues after
- **D - Incorrect:** Compensating compensates for weaknesses

Q46: Detective Control

Question

Reviewing audit logs in a SIEM tool is an example of:

- ☐ A Corrective control
- ☐ B Detective control
- ☐ C Compensating control
- ☐ D Deterrent control

Q46: Explanation

Correct Answer: B

Reviewing audit logs is detective control - it identifies issues after they occur.

Option Analysis

- **A - Incorrect:** Corrective fixes issues
- **B - Correct:** Detective identifies issues
- **C - Incorrect:** Compensating compensates
- **D - Incorrect:** Deterrent discourages actions

Q47: Deterrent Control

Question

Installing security cameras to secure a data center is:

- ☐ A Corrective control
- ☐ B Detective control
- ☐ C Compensating control
- ☐ D Deterrent control

Q47: Explanation

Correct Answer: D

Security cameras are a deterrent control - they discourage malicious activity.

Option Analysis

- **A - Incorrect:** Corrective would fix issues
- **B - Incorrect:** Detective would identify issues
- **C - Incorrect:** Compensating would compensate
- **D - Correct:** Deterrent discourages activity

Q48: Compensating Control

Question

A risk manager introduced additional oversight of an accounting system where logical controls are not implemented. This is:

- ☐ A Corrective control
- ☐ B Detective control
- ☐ C Compensating control
- ☐ D Deterrent control

Q48: Explanation

Correct Answer: C

Additional oversight compensating for missing logical controls is a compensating control.

Option Analysis

- **A - Incorrect:** Corrective would fix the issue
- **B - Incorrect:** Detective would identify
- **C - Correct:** Compensating compensates for weakness
- **D - Incorrect:** Deterrent would discourage

Q49: Corrective Control

Question

An IT system failed during changes and lost data. Risk manager advises restoring from backups. This is:

- ☐ A Corrective control
- ☐ B Detective control
- ☐ C Compensating control
- ☐ D Deterrent control

Q49: Explanation

Correct Answer: A

Restoring from backups to fix an issue is a corrective control.

Option Analysis

- **A - Correct:** Corrective fixes the issue
- **B - Incorrect:** Detective would identify
- **C - Incorrect:** Compensating would compensate
- **D - Incorrect:** Deterrent would discourage

Q50: Post-Incident Controls

Question

Which control categories are used after the incident has happened?

- Ⓐ Corrective, compensating
- Ⓑ Corrective, deterrent
- Ⓒ Corrective, detective
- Ⓓ Deterrent, preventive

Q50: Explanation

Correct Answer: C

Detective and corrective controls are used after the incident has happened.

Option Analysis

- **A - Incorrect:** Compensating is ongoing
- **B - Incorrect:** Deterrent is before
- **C - Correct:** Detective and corrective are after
- **D - Incorrect:** Deterrent/preventive are before

Q51: Parallel Changeover

Question

Risk manager overseeing critical system upgrade with no downtime. Recommendation should be:

- Ⓐ Parallel
- Ⓑ Phased
- Ⓒ Abrupt
- Ⓓ Any of the above

Q51: Explanation

Correct Answer: A

Parallel changeover allows both systems to run simultaneously with no downtime.

Option Analysis

- **A - Correct:** Parallel ensures no downtime
- **B - Incorrect:** Phased may have downtime
- **C - Incorrect:** Abrupt has high risk
- **D - Incorrect:** Parallel is best for no downtime

Q52: Phased Changeover

Question

System upgrading per module with no dependencies. Most efficient method?

- ☐ A Parallel
- ☐ B Phased
- ☐ C Abrupt
- ☐ D Any of the above

Q52: Explanation

Correct Answer: B

Phased changeover is most efficient when modules are independent.

Option Analysis

- **A - Incorrect:** Parallel is expensive
- **B - Correct:** Phased works well with independent modules
- **C - Incorrect:** Abrupt is too risky
- **D - Incorrect:** Phased is most efficient

Q53: Post-Implementation Audience

Question

Who should be the target audience for a post-implementation review?

- ☐ A Developers
- ☐ B Risk manager
- ☐ C Risk owner
- ☐ D All major stakeholders

Q53: Explanation

Correct Answer: D

All major stakeholders should participate in post-implementation review.

Option Analysis

- **A - Incorrect:** Developers alone insufficient
- **B - Incorrect:** Risk manager alone insufficient
- **C - Incorrect:** Risk owner alone insufficient
- **D - Correct:** All stakeholders needed

Q54: Log Aggregation Purpose

Question

What is the primary purpose of log aggregation in an organization?

- Ⓐ Identify and analyze important events
- Ⓑ Synchronize clocks
- Ⓒ Eliminate need for logging
- Ⓓ Provide centralized storage only

Q54: Explanation

Correct Answer: A

Log aggregation helps identify and analyze important events and potential incidents.

Option Analysis

- **A - Correct:** Identification and analysis of events
- **B - Incorrect:** Clock sync is separate
- **C - Incorrect:** Doesn't eliminate logging
- **D - Incorrect:** Storage is not primary purpose

Question

Which is a commonly used tool for log aggregation and analysis?

- ☐ A SIEM system
- ☐ B Vulnerability assessment tool
- ☐ C Penetration testing tool
- ☐ D Heat map generator

Q55: Explanation

Correct Answer: A

SIEM systems are commonly used for log aggregation and analysis.

Option Analysis

- **A - Correct:** SIEM handles log aggregation
- **B - Incorrect:** VA tools find vulnerabilities
- **C - Incorrect:** Pen testing finds exploits
- **D - Incorrect:** Heat maps are visualization

Question

What is the role of KRIs in risk monitoring?

- Ⓐ Predict risks that may breach thresholds
- Ⓑ Measure effectiveness of controls
- Ⓒ Indicate weaknesses in controls
- Ⓓ Assess control performance

Q56: Explanation

Correct Answer: A

KRIs predict risks that may breach predefined thresholds.

Option Analysis

- **A - Correct:** KRIs predict risk breaches
- **B - Incorrect:** KPIs measure effectiveness
- **C - Incorrect:** KCIs indicate weaknesses
- **D - Incorrect:** KPIs assess performance

Q57: Dashboard Characteristics

Question

Which format of risk reporting is known for flexibility in combining qualitative and quantitative metrics?

- ☐ A Executive summary
- ☐ B Heat map
- ☐ C Scorecard
- ☐ D Dashboard

Q57: Explanation

Correct Answer: D

Dashboards combine qualitative and quantitative metrics with flexibility.

Option Analysis

- **A - Incorrect:** Summary is text-based
- **B - Incorrect:** Heat map is qualitative only
- **C - Incorrect:** Scorecard is qualitative
- **D - Correct:** Dashboard is flexible

Q58: SMART Metrics

Question

What are the key characteristics of a SMART metric?

- Ⓐ Specific, Measurable, Attainable, Relevant, Timely
- Ⓑ Standardized, Meaningful, Achievable, Realistic, Timeless
- Ⓒ Secure, Measurable, Aligned, Reliable, Trustworthy
- Ⓓ Significant, Measurable, Accurate, Relevant, Timed

Q58: Explanation

Correct Answer: A

SMART stands for Specific, Measurable, Attainable, Relevant, Timely.

Option Analysis

- **A - Correct:** Standard SMART definition
- **B - Incorrect:** Not standard SMART
- **C - Incorrect:** Not standard SMART
- **D - Incorrect:** Not standard SMART

Q59: Penetration Testing

Question

Which technique involves simulating a real attack to identify undiscovered vulnerabilities?

- Ⓐ Self-assessment
- Ⓑ Internal audit
- Ⓒ Vulnerability assessment
- Ⓓ Penetration testing

Q59: Explanation

Correct Answer: D

Penetration testing simulates real attacks to identify vulnerabilities.

Option Analysis

- **A - Incorrect:** Self-assessment is internal review
- **B - Incorrect:** Audit is compliance review
- **C - Incorrect:** VA finds known vulnerabilities
- **D - Correct:** Penetration test simulates attacks

Q60: Technology Architecture

Question

Networking devices, storage, and software are components of:

- Ⓐ Business architecture
- Ⓑ Technology architecture
- Ⓒ Data architecture
- Ⓓ Application architecture

Q60: Explanation

Correct Answer: B

Networking devices, storage, and software are components of technology architecture.

Option Analysis

- **A - Incorrect:** Business architecture defines processes
- **B - Correct:** Technology architecture covers infrastructure
- **C - Incorrect:** Data architecture covers data management
- **D - Incorrect:** Application architecture covers software solutions

Q61: CMM Defined Process

Question

Which is NOT a property of the Defined process in CMM?

- ☐ A Well characterized and understood
- ☐ B Defined at organizational level
- ☐ C Proactive
- ☐ D Unpredictable

Q61: Explanation

Correct Answer: D

Unpredictable is not a property of Defined process in CMM.

Option Analysis

- **A - True:** Well characterized
- **B - True:** Defined at organizational level
- **C - True:** Proactive
- **D - Not True:** Defined processes are predictable

Q62: TCP/IP Model Layers

Question

Which is Layer 3 of the TCP/IP model?

- ☐ A Physical
- ☐ B Data link
- ☐ C Network
- ☐ D Application

Q62: Explanation

Correct Answer: C

Network layer is Layer 3 of the TCP/IP model.

Option Analysis

- **A - Incorrect:** Physical is Layer 1
- **B - Incorrect:** Data link is Layer 2
- **C - Correct:** Network is Layer 3
- **D - Incorrect:** Application is Layer 5

Q63: OSI Model Session Layer

Question

Which is Layer 5 of the OSI model?

- ☐ A Physical
- ☐ B Application
- ☐ C Session
- ☐ D Transport

Q63: Explanation

Correct Answer: C

Session layer is Layer 5 of the OSI model.

Option Analysis

- **A - Incorrect:** Physical is Layer 1
- **B - Incorrect:** Application is Layer 7
- **C - Correct:** Session is Layer 5
- **D - Incorrect:** Transport is Layer 4

Q64: VPN Protocol

Question

Which protocol is used to implement a VPN?

- ☐ A DNS
- ☐ B IPSec
- ☐ C SSL
- ☐ D SSO

Q64: Explanation

Correct Answer: B

IPSec protocol is commonly used to implement VPNs.

Option Analysis

- **A - Incorrect:** DNS is domain name service
- **B - Correct:** IPSec enables VPN
- **C - Incorrect:** SSL is for web encryption
- **D - Incorrect:** SSO is single sign-on

Question

Which is an example of on-demand compute, network, and storage services?

- ☐ A PaaS
- ☐ B SaaS
- ☐ C IaaS
- ☐ D NaaS

Q65: Explanation

Correct Answer: C

IaaS provides on-demand compute, network, and storage services.

Option Analysis

- **A - Incorrect:** PaaS provides platform
- **B - Incorrect:** SaaS provides software
- **C - Correct:** IaaS provides infrastructure
- **D - Incorrect:** NaaS provides network services

Q66: SaaS Example

Question

An online platform for video games is an example of:

- ☐ A PaaS
- ☐ B SaaS
- ☐ C IaaS
- ☐ D NaaS

Q66: Explanation

Correct Answer: B

Online video game platform that lets users play without installing software is SaaS.

Option Analysis

- **A - Incorrect:** PaaS provides development platform
- **B - Correct:** SaaS provides ready-to-use software
- **C - Incorrect:** IaaS provides infrastructure
- **D - Incorrect:** NaaS provides network

Q67: Private Cloud

Question

In which deployment model are underlying cloud services NOT shared with other customers?

- Ⓐ Public
- Ⓑ Private
- Ⓒ Community
- Ⓓ Hybrid

Q67: Explanation

Correct Answer: B

Private cloud resources are dedicated to a single organization.

Option Analysis

- **A - Incorrect:** Public is shared
- **B - Correct:** Private is dedicated
- **C - Incorrect:** Community is shared with similar orgs
- **D - Incorrect:** Hybrid combines models

Q68: Community Cloud

Question

In which deployment model are underlying cloud services shared with similar customers?

- ☐ A Public
- ☐ B Private
- ☐ C Community
- ☐ D Hybrid

Q68: Explanation

Correct Answer: C

Community cloud lets similar organizations share resources.

Option Analysis

- **A - Incorrect:** Public is open to all
- **B - Incorrect:** Private is dedicated
- **C - Correct:** Community is for similar orgs
- **D - Incorrect:** Hybrid combines models

Q69: BIA Input for BCP

Question

Which acts as an input for the BCP?

- ☐ A Recovery objectives
- ☐ B DR test
- ☐ C BIA
- ☐ D BC test

Q69: Explanation

Correct Answer: C

BIA is the input to creating a BCP.

Option Analysis

- **A - Incorrect:** Recovery objectives are output of BIA
- **B - Incorrect:** DR test validates recovery
- **C - Correct:** BIA inputs BCP
- **D - Incorrect:** BC test validates BCP

Question

Risk manager confirms application can't lose more than four hours of data. Which objective is this?

- ☐ A MTD
- ☐ B RPO
- ☐ C RTO
- ☐ D BIA

Q70: Explanation

Correct Answer: B

RPO is the maximum acceptable data loss - in this case, 4 hours.

Option Analysis

- **A - Incorrect:** MTD is total downtime
- **B - Correct:** RPO measures data loss tolerance
- **C - Incorrect:** RTO measures downtime tolerance
- **D - Incorrect:** BIA is the assessment process

Q71: RTO and MTD

Question

An application can tolerate four hours of downtime but must be recovered within six hours. Which metrics are correct?

- Ⓐ RPO - 4h, RTO - 6h
- Ⓑ MTD - 4h, RTO - 6h
- Ⓒ MTD - 6h, RPO - 4h
- Ⓓ RTO - 4h, MTD - 6h

Q71: Explanation

Correct Answer: D

RTO is maximum acceptable downtime (4h). MTD is maximum total downtime before material impact (6h).

Option Analysis

- **A - Incorrect:** RPO is data loss, not downtime
- **B - Incorrect:** MTD should be 6h, not 4h
- **C - Incorrect:** MTD is 6h not 4h
- **D - Correct:** RTO=4h (downtime tolerance), MTD=6h (total before impact)

Q72: Data Classification

Question

Healthcare records and driver's licenses - most appropriate classification?

- ☐ A Sensitive (PII and PHI)
- ☐ B Public
- ☐ C PII
- ☐ D PHI

Q72: Explanation

Correct Answer: A

Contains both PII and PHI, so classification should be Sensitive.

Option Analysis

- **A - Correct:** Sensitive covers both PII and PHI
- **B - Incorrect:** Public is for non-sensitive data
- **C - Incorrect:** PII alone doesn't cover health records
- **D - Incorrect:** PHI alone doesn't cover driver's licenses

Q73: Data Destruction

Question

Which stage of data life cycle includes disposal of data?

- ☐ A Destruction
- ☐ B Archival
- ☐ C Use
- ☐ D Storage

Q73: Explanation

Correct Answer: A

Destruction stage includes disposal of data.

Option Analysis

- **A - Correct:** Destruction is disposal
- **B - Incorrect:** Archival is long-term storage
- **C - Incorrect:** Use is processing
- **D - Incorrect:** Storage is saving data

Q74: Data Labeling Purpose

Question

Data labeling is important for which of the following?

- ☐ A Data archival
- ☐ B Data destruction
- ☐ C DLP
- ☐ D All of the above

Q74: Explanation

Correct Answer: D

Data labeling is important for archival, destruction, and DLP.

Option Analysis

- **A - Incorrect:** Archival alone not complete
- **B - Incorrect:** Destruction alone not complete
- **C - Incorrect:** DLP alone not complete
- **D - Correct:** All functions benefit from labeling

Q75: SDLC Budget Phase

Question

A project is budgeted in which phase of the SDLC?

- ☐ A Development
- ☐ B Disposal
- ☐ C Initiation
- ☐ D Maintenance

Q75: Explanation

Correct Answer: C

Budgeting occurs in the initiation phase of SDLC.

Option Analysis

- **A - Incorrect:** Development is coding
- **B - Incorrect:** Disposal is retirement
- **C - Correct:** Initiation includes budgeting
- **D - Incorrect:** Maintenance is ongoing support

Q76: User Training Phase

Question

End user training is an integral part of which phase of the SDLC?

- Ⓐ Development
- Ⓑ Disposal
- Ⓒ Initiation
- Ⓓ Implementation

Q76: Explanation

Correct Answer: D

End users are trained in the implementation phase.

Option Analysis

- **A - Incorrect:** Development is coding
- **B - Incorrect:** Disposal is retirement
- **C - Incorrect:** Initiation is planning
- **D - Correct:** Implementation includes training

Q77: SDLC Final Stage

Question

Which is the final stage of the SDLC?

- ☐ A Development
- ☐ B Disposal
- ☐ C Initiation
- ☐ D Maintenance

Q77: Explanation

Correct Answer: B

Disposal is the final phase of the SDLC.

Option Analysis

- **A - Incorrect:** Development is early phase
- **B - Correct:** Disposal is final phase
- **C - Incorrect:** Initiation is first phase
- **D - Incorrect:** Maintenance is ongoing

Q78: Project Risk vs SDLC Risk

Question

Key difference between project risk and SDLC risk is:

- ☐ A Project risk relates to objectives, SDLC relates to time
- ☐ B Project risk relates to objectives, SDLC relates to development
- ☐ C Project risk relates to development, SDLC relates to objectives
- ☐ D There is no difference

Q78: Explanation

Correct Answer: B

Project risk relates to project objectives; SDLC risk relates to development objectives.

Option Analysis

- **A - Incorrect:** SDLC risk is not just time
- **B - Correct:** Different focuses
- **C - Incorrect:** Reversed relationship
- **D - Incorrect:** They are different

Q79: Certification Requirement

Question

Which is a must to achieve certification?

- ☐ A A risk manager
- ☐ B An internal audit team
- ☐ C Policies
- ☐ D An external audit firm

Q79: Explanation

Correct Answer: D

An external audit firm is required to certify a product.

Option Analysis

- **A - Incorrect:** Risk manager may not be required
- **B - Incorrect:** Internal audit cannot certify externally
- **C - Incorrect:** Policies alone don't certify
- **D - Correct:** External audit firm is required

Question

Practice of allowing employees to use personal laptops to access organizational resources is called:

- ☐ A Remote working
- ☐ B BYOD
- ☐ C Virtual computing
- ☐ D Cloud computing

Q80: Explanation

Correct Answer: B

BYOD (Bring Your Own Device) allows personal devices to access organization resources.

Option Analysis

- **A - Incorrect:** Remote working is broader
- **B - Correct:** BYOD specifically allows personal devices
- **C - Incorrect:** Virtual computing is different
- **D - Incorrect:** Cloud computing is different

Q81: Quantum Computing

Question

Which technology has potential to break current encryption algorithms?

- ☐ A AI
- ☐ B Blockchain
- ☐ C Quantum computing
- ☐ D IoT

Q81: Explanation

Correct Answer: C

Quantum computing has the potential to break current encryption algorithms.

Option Analysis

- **A - Incorrect:** AI doesn't break encryption
- **B - Incorrect:** Blockchain is distributed ledger
- **C - Correct:** Quantum computing breaks encryption
- **D - Incorrect:** IoT doesn't break encryption

Q82: Encryption Keys

Question

Which keys are required for asymmetric key encryption?

- ☐ A Only public key
- ☐ B Only private key
- ☐ C Any public or private key
- ☐ D Public and private key pair

Q82: Explanation

Correct Answer: D

Asymmetric encryption requires both a public key and a private key.

Option Analysis

- **A - Incorrect:** Public key alone insufficient
- **B - Incorrect:** Private key alone insufficient
- **C - Incorrect:** Need both keys
- **D - Correct:** Both keys are required

Q83: Symmetric Encryption

Question

Which key is required for symmetric key encryption?

- Ⓐ Public and private key
- Ⓑ A single key for encryption and decryption
- Ⓒ Only public key and hash
- Ⓓ Only private key and hash

Q83: Explanation

Correct Answer: B

Symmetric encryption uses a single key for both encryption and decryption.

Option Analysis

- **A - Incorrect:** That's asymmetric
- **B - Correct:** Single key for both
- **C - Incorrect:** Public key is asymmetric
- **D - Incorrect:** Private key is asymmetric

Q84: Integrity Definition

Question

Integrity of information means that:

- ☐ A Information is available to authorized users only
- ☐ B Information is available at all times
- ☐ C Information has not been tampered with
- ☐ D All of these

Q84: Explanation

Correct Answer: C

Integrity means information has not been tampered with.

Option Analysis

- **A - Incorrect:** That's confidentiality
- **B - Incorrect:** That's availability
- **C - Correct:** Integrity is no tampering
- **D - Incorrect:** Only C is correct

Q85: Confidentiality Definition

Question

Confidentiality of information means that:

- ☐ A Information is available to authorized users only
- ☐ B Information is available at all times
- ☐ C Information has not been tampered with
- ☐ D All of these

Q85: Explanation

Correct Answer: A

Confidentiality means information is available to authorized users only.

Option Analysis

- **A - Correct:** Confidentiality limits access
- **B - Incorrect:** That's availability
- **C - Incorrect:** That's integrity
- **D - Incorrect:** Only A is correct

Q86: Availability Definition

Question

Availability of information means that:

- ☐ A Information is available to authorized users only
- ☐ B Information is available at all times to authorized users
- ☐ C Information has not been tampered with
- ☐ D All of these

Q86: Explanation

Correct Answer: B

Availability means information is accessible when needed by authorized users.

Option Analysis

- **A - Incorrect:** That's confidentiality
- **B - Correct:** Availability is timely access
- **C - Incorrect:** That's integrity
- **D - Incorrect:** Only B is correct

Q87: Accountability

Question

Which access control principle speaks to logging and monitoring of user activities?

- Ⓐ Identification
- Ⓑ Authentication
- Ⓒ Authorization
- Ⓓ Accountability

Q87: Explanation

Correct Answer: D

Accountability deals with logging and monitoring of user activities.

Option Analysis

- **A - Incorrect:** Identification is unique ID
- **B - Incorrect:** Authentication is verification
- **C - Incorrect:** Authorization is permissions
- **D - Correct:** Accountability is logging/monitoring

Q88: Identification

Question

Which access control principle requires each user to have a separate unique name?

- ☒ A Identification
- ☐ B Authentication
- ☐ C Authorization
- ☐ D Accountability

Q88: Explanation

Correct Answer: A

Identification requires all users to have a unique ID.

Option Analysis

- **A - Correct:** Identification requires unique ID
- **B - Incorrect:** Authentication verifies identity
- **C - Incorrect:** Authorization sets permissions
- **D - Incorrect:** Accountability logs activity

Q89: Segregation of Duties

Question

SOD principle ensures that:

- Ⓐ All admin access to a single user
- Ⓑ Access to approve transactions is distributed
- Ⓒ Confidentiality is maintained
- Ⓓ Identification is in place

Q89: Explanation

Correct Answer: B

SOD ensures no single user has sole access to approve transactions.

Option Analysis

- **A - Incorrect:** SOD prevents single control
- **B - Correct:** SOD distributes authority
- **C - Incorrect:** Confidentiality is separate
- **D - Incorrect:** Identification is separate

Q90: Hashing Characteristics

Question

Which is true about hashing?

- ☐ A Provides unique output for each input
- ☐ B Is non-reversible
- ☐ C Helps maintain integrity
- ☐ D All of these

Q90: Explanation

Correct Answer: D

All options are true for hashing - unique output, non-reversible, and integrity.

Option Analysis

- **A - True:** Unique output
- **B - True:** Non-reversible
- **C - True:** Integrity verification
- **D - Correct:** All are true

Q91: Digital Signatures

Question

Which is NOT provided by digital signatures?

- Ⓐ Integrity
- Ⓑ Non-repudiation
- Ⓒ Authenticity
- Ⓓ Confidentiality

Q91: Explanation

Correct Answer: D

Digital signatures do NOT provide confidentiality on their own.

Option Analysis

- **A - Incorrect:** Integrity is provided
- **B - Incorrect:** Non-repudiation is provided
- **C - Incorrect:** Authenticity is provided
- **D - Correct:** Confidentiality is not provided

Q92: Encryption and Confidentiality

Question

Sender wants only receiver to decrypt data. Which should sender use?

- Ⓐ Receiver's public key
- Ⓑ Sender's public key
- Ⓒ Receiver's private key
- Ⓓ Sender's private key

Q92: Explanation

Correct Answer: A

Use receiver's public key to encrypt so only receiver can decrypt with their private key.

Option Analysis

- **A - Correct:** Receiver's public key ensures only receiver decrypts
- **B - Incorrect:** Anyone with sender's public key
- **C - Incorrect:** Receiver's private key is not shared
- **D - Incorrect:** Sender's private key would allow anyone

Q93: Signed and Encrypted

Question

Which cryptographic mechanism provides confidentiality, integrity, and non-repudiation?

- Ⓐ Signed, not encrypted
- Ⓑ Encrypted, not signed
- Ⓒ Signed, encrypted
- Ⓓ Signed, hashed

Q93: Explanation

Correct Answer: C

Signed and encrypted provides confidentiality, integrity, and non-repudiation.

Option Analysis

- **A - Incorrect:** No confidentiality
- **B - Incorrect:** No integrity/non-repudiation
- **C - Correct:** All three provided
- **D - Incorrect:** No confidentiality

Question

Which could be a SPOF in the PKI ecosystem?

- ☐ A Certificate
- ☐ B CA
- ☐ C Requester
- ☐ D Browser

Q94: Explanation

Correct Answer: B

CA could be a SPOF if its private key is compromised.

Option Analysis

- **A - Incorrect:** Individual certificate isn't SPOF
- **B - Correct:** CA compromise affects all
- **C - Incorrect:** Requester isn't SPOF
- **D - Incorrect:** Browser isn't SPOF

Q95: Security Awareness Primary Goal

Question

Most important aspect of security awareness training is:

- Ⓐ Train on latest threats
- Ⓑ Show compliance with audits
- Ⓒ Create security-conscious culture
- Ⓓ Upskill employees

Q95: Explanation

Correct Answer: C

Most important goal is to create a security-conscious culture.

Option Analysis

- **A - Incorrect:** Latest threats change
- **B - Incorrect:** Compliance is secondary
- **C - Correct:** Culture is primary
- **D - Incorrect:** Upskilling is secondary

Q96: Data Privacy

Question

Data privacy should be:

- ☐ A Each individual's right
- ☐ B Supported by security controls
- ☐ C Embedded into system design
- ☐ D All of these

Q96: Explanation

Correct Answer: D

Data privacy should be each individual's right, supported by controls, and embedded in design.

Option Analysis

- **A - Incorrect:** Right alone not enough
- **B - Incorrect:** Controls alone not enough
- **C - Incorrect:** Design alone not enough
- **D - Correct:** All aspects are needed

Q97: Data Security vs Privacy

Question

Which statement is true about data security and data privacy?

- Ⓐ They are the same thing
- Ⓑ Security is protecting data; privacy is protecting personal information
- Ⓒ Privacy is protecting data; security is protecting personal information
- Ⓓ Not important for organizations

Q97: Explanation

Correct Answer: B

Data security protects data from unauthorized access; data privacy protects personal information from misuse.

Option Analysis

- **A - Incorrect:** They are different
- **B - Correct:** Security vs privacy distinction
- **C - Incorrect:** Reversed
- **D - Incorrect:** Both are important

Q98: Privacy Compliance

Question

Company collecting customer data for marketing. Which measure ensures compliance with privacy regulations?

- Ⓐ Use encryption
- Ⓑ Obtain consent
- Ⓒ Implement firewalls
- Ⓓ Train employees

Q98: Explanation

Correct Answer: B

Obtaining consent is critical for compliance with GDPR, CCPA, and other privacy regulations.

Option Analysis

- **A - Incorrect:** Encryption is security, not privacy
- **B - Correct:** Consent is required
- **C - Incorrect:** Firewalls are security
- **D - Incorrect:** Training is important but not primary

Q99: Vulnerability Management KPI

Question

Which KPI is most appropriate to measure vulnerability management program effectiveness?

- Ⓐ Number of vulnerabilities found and remediated
- Ⓑ Number of security incidents reported
- Ⓒ Percentage of employees trained
- Ⓓ Average incident response time

Q99: Explanation

Correct Answer: A

Number of vulnerabilities found and remediated measures vulnerability management effectiveness.

Option Analysis

- **A - Correct:** Direct measure of VM program
- **B - Incorrect:** Measures incident response
- **C - Incorrect:** Measures training program
- **D - Incorrect:** Measures IR effectiveness

Q100: Security Program KPI

Question

Which KPI is most useful to evaluate security program effectiveness over time?

- Ⓐ Number of employees trained
- Ⓑ Number of security incidents reported
- Ⓒ Average detection and response time
- Ⓓ Percentage reduction in data breaches

Q100: Explanation

Correct Answer: D

Percentage reduction in data breaches directly measures program impact over time.

Option Analysis

- **A - Incorrect:** Training completion not a direct measure
- **B - Incorrect:** Incidents may change
- **C - Incorrect:** Response time is operational
- **D - Correct:** Direct measure of program success

Essential Concepts

- Governance provides oversight and direction from Board
- Risk identification is the first step - "You can't protect what you don't know"
- Risk Appetite = willingness to accept risk
- Risk Tolerance = acceptable variation from appetite
- Risk Capacity = maximum risk before existence threatened
- RPO is backward-looking; RTO is forward-looking

CRISC Key Takeaways (continued)

More Essential Concepts

- 3LoD: First = Operations, Second = Oversight, Third = Audit
- Residual Risk = Inherent Risk - Controls
- Risk Response: Mitigate, Accept, Transfer, Avoid
- SMART: Specific, Measurable, Attainable, Relevant, Timely
- CIA: Confidentiality, Integrity, Availability
- Digital signatures: Integrity, Non-repudiation, Authenticity (NOT confidentiality)

Exam Preparation

Remember:

- Understand the *why* behind each concept
- Know control categories and their differences
- Understand recovery objectives (RPO, RTO, MTD)
- Know risk appetite vs tolerance vs capacity
- Practice scenario-based questions

Good Luck on Your CRISC Exam!